

智能晨检仪双向接口对接文档

1. 文档信息

项目	内容
文档版本	v1.1
编制日期	2026-08-27
适用版本	Android App 1.0.21, versionCode=23
接口方向	设备调用平台，以及平台/客户系统调用设备
接口数量	平台侧 7 个，设备侧 18 个
事实来源	当前 feature/shi-an 分支代码与自动化契约测试

本文同时描述第三方平台必须实现的接口，以及晨检仪自身提供的设备端 REST API。

2. 平台侧对接结论

第三方平台必须实现以下接口：

序号	方法	路径	用途
1	POST	/api/device/refresh	设备心跳
2	POST	/api/device/morning-check/upload	晨检记录上报
3	POST	/api/device/employees/changes	设备上传员工变更
4	GET	/api/device/employees/changes	设备拉取员工增量
5	GET	/api/device/employees/{employeeId}	查询单个员工最新状态
6	GET	/api/device/employees/snapshot	拉取完整员工快照
7	GET	/api/device/employees/images/{fileId}	下载员工图片

设备配置的“平台地址”必须是平台根地址，例如：

```
https://platform.example.com
```

不要配置成：

```
https://platform.example.com/api/device
```

设备会自行追加 /api/device/...。平台地址末尾有 / 时设备会自动移除。

生产对接必须直接使用有效 HTTPS 地址。晨检记录上报代码会拒绝 HTTP 地址，也不能依赖 HTTP 301/302 跳转升级到 HTTPS。

3. 通用协议

3.1 认证

所有 7 个接口都使用以下请求头：

```
api-key: {平台分配给设备的 API Key}
```

JSON 请求还会携带：

```
Content-Type: application/json
```

平台应通过 API Key 识别租户、食堂和设备。平台必须校验请求中的 `device_id` 是否属于该 API Key。

3.2 通用 JSON 响应

除图片下载外，成功响应统一使用：

```
{
  "code": 200,
  "message": "success",
  "data": {}
}
```

员工同步接口兼容 `msg` 作为错误消息字段，但新平台统一返回 `message`：

```
{
  "code": 40010,
  "message": "invalid request",
  "data": null
}
```

设备的成功判定：

接口	HTTP 要求	业务要求
心跳	任意 2xx	code=200
晨检记录上报	必须为 200	code=200，且 data.recordIds 长度为 1
员工同步 JSON 接口	任意 2xx	code=200，且 data 非空

接口	HTTP 要求	业务要求
图片下载	任意 2xx	响应不是 JSON，图片 SHA-256 与平台下发值一致

3.3 时间、编码和标识

- 时间戳均为 Unix 毫秒时间戳。
- 健康证日期格式为 YYYY-MM-DD。
- JSON 编码为 UTF-8。
- Base64 不带 data:image/...;base64, 前缀，不包含换行。
- operation_id、batch_id、record_uuid 使用 UUID 字符串。
- employeeId 和 fileId 会进入 URL 路径，不得包含 /、?、#。

3.4 当前客户端超时

调用	请求超时
心跳连接测试	20 秒
普通心跳	30 秒
晨检记录上报	30 秒
员工增量、单员工查询	15 秒
员工变更上传、快照、图片下载	60 秒

平台应在超时前返回完整响应。不要先返回 200 再异步决定业务是否成功。

4. 设备心跳

4.1 请求

```
POST /api/device/refresh
api-key: {API Key}
```

请求体为空。设备不会在心跳请求体中发送 device_id。

默认每 30 秒发送一次，设备侧可配置范围为 10 至 300 秒。App 启动约 5 秒后会立即发送一次。

4.2 成功响应

最小可用响应：

```
{
  "code": 200,
  "message": "success"
}
```

完整响应：

```
{
  "code": 200,
  "message": "success",
  "data": {
    "device_id": "DEVICE001",
    "status": "online",
    "last_heartbeat": "2026-08-27T12:00:00Z"
  }
}
```

data 及其内部字段对设备均为可选。平台从故障恢复且心跳重新成功后，设备会立即触发积压晨检记录补传。

5. 晨检记录上报

5.1 请求

```
POST /api/device/morning-check/upload
Content-Type: application/json
api-key: {API Key}
```

当前每次只上报一条晨检记录，**employees** 长度固定为 1。

```
{
  "device_id": "DEVICE001",
  "timestamp": 1787788800000,
  "employees": [
    {
      "employee_id": "E001",
      "name": "张三",
      "record_id": 1001,
      "record_uuid": "7ed7724e-cf2d-4b7d-a2e1-9a539e87bb24",
      "user_id": 1,
      "temperature": 36.5,
      "is_temp_normal": true,
      "is_hand_normal": false,
      "is_passed": false,
      "hand_status": "ABNORMAL",
      "has_foreign_object": true,
      "hand_abnormal_types": ["ring"],
      "health_cert_status": "VALID",
      "symptom_flags": ["COUGH"],
      "remark": "手部检出戒指",
      "photo": "/9j/4AAQSkZJRgABAQ...",
      "hand_palm_photo": "/9j/4AAQSkZJRgABAQ...",
      "hand_back_photo": null
    }
  ]
}
```

```
    }
  ]
}
```

5.2 请求字段

字段	类型	必填	说明
device_id	string	是	该记录首次上传时确定的稳定设备编码
timestamp	long	是	晨检发生时间，重试时保持不变
employees	array	是	当前长度必须为 1
employees[].employee_id	string	是	平台员工业务主键
employees[].name	string	是	晨检发生时的姓名快照
employees[].record_id	long	是	设备本地记录 ID，仅用于追溯
employees[].record_uuid	string	是	设备生成的稳定记录 UUID
employees[].user_id	long	是	设备本地用户 ID，不用于平台员工匹配
employees[].temperature	float	是	摄氏温度
employees[].is_temp_normal	boolean	是	体温是否正常
employees[].is_hand_normal	boolean/null	是	正常 true，异常 false，未检查 null
employees[].is_passed	boolean	是	设备最终晨检判定
employees[].hand_status	string	是	NORMAL、ABNORMAL、NOT_CHECKED
employees[].has_foreign_object	boolean/null	是	有异物 true，无异物 false，未检查 null
employees[].hand_abnormal_types	string[]	是	无异常时为 []
employees[].health_cert_status	string	是	健康证状态快照
employees[].symptom_flags	string[]	是	无症状时为 []
employees[].remark	string	是	无备注时为 ""
employees[].photo	string/null	是	JPEG 原始 Base64，无图片为 null
employees[].hand_palm_photo	string/null	是	手心 JPEG Base64，无图片为 null
employees[].hand_back_photo	string/null	是	手背 JPEG Base64，无图片为 null

设备序列化时会保留三个图片字段；无图明确发送 JSON null。

5.3 枚举

hand_abnormal_types 可包含：

值	含义
band_aid	创可贴
bracelet	手链或手环
ring	戒指
watch	手表
foreign	其他异物

health_cert_status 可包含：

VALID、EXPIRING_SOON、EXPIRED、NOT_PROVIDED、REVOKED、NOT_CHECKED、UNKNOWN。

symptom_flags 可包含：

COUGH、FEVER、VOMITING、RUNNY_NOSE、RASH、HEADACHE、FATIGUE、SORE_THROAT、DIARRHEA、OTHER。

5.4 判定一致性

is_passed=true 时必须同时满足：

- temperature < 37.3 且 is_temp_normal=true
- hand_status=NORMAL
- is_hand_normal=true
- has_foreign_object=false
- health_cert_status 为 VALID 或 EXPIRING_SOON
- symptom_flags=[]

平台应保存设备原始判定，不应静默修改。字段矛盾时建议返回 HTTP 422。

5.5 图片和请求大小

- 图片统一重新编码为 JPEG。
- 最长边不超过 1280 像素。
- 单张压缩后不超过 2 MiB。
- 三张图片 Base64 字符总量不超过 9 MiB。
- 完整 JSON 请求体不超过 10 MiB。
- Base64 无效、图片无效或超限时，平台应返回 HTTP 422。

5.6 幂等

平台唯一键必须使用：

device_id + record_uuid

相同唯一键和相同内容重复提交时，返回原平台记录 ID并按成功处理。相同唯一键但内容不同，应返回 HTTP 409 Conflict，不得覆盖原记录。

5.7 成功响应

```
{
  "code": 200,
  "message": "success",
  "data": {
    "recordIds": ["REC001"],
    "processTime": 120,
    "warnings": [],
    "capture_image_url": "/uploads/morning-check/face.jpg",
    "hand_palm_image_url": "/uploads/morning-check/palm.jpg",
    "hand_back_image_url": null
  },
  "request_id": "cf8ee2849bc34c5e8ad34a2d9997a0bd"
}
```

平台成功响应的强制字段：

字段	类型	约束
code	int	必须为 200
message	string	必须存在
data	object	必须存在
data.recordIds	string[]	必须存在且长度为 1

processTime、warnings、三个图片 URL 和 request_id 当前客户端均可缺省，但建议完整返回。

5.8 错误和重试

结果	设备行为
网络错误或超时	自动重试
HTTP 408、429、5xx	自动重试
其他非 200 HTTP	停止自动重试
HTTP 200 且业务 code<=500	自动重试
HTTP 200 且其他非 200 业务码	停止自动重试
成功响应缺少唯一一个 recordIds	停止自动重试，记为协议错误

重试间隔为 1、2、4、8、16、32、60 分钟，之后保持 60 分钟。重试期间请求业务内容、`device_id` 和 `record_uuid` 不变。

6. 员工同步公共模型

6.1 平台下发员工对象

```
{
  "employee_id": "E001",
  "name": "张三",
  "id_card_number": "110101199001011234",
  "phone": "13800138000",
  "position": "厨师",
  "department": "后厨",
  "status": "ACTIVE",
  "face_image": {
    "file_id": "face-E001-v4",
    "sha256":
"6272c21f5b5b2c0f6c40c890f0a56eebf845f2482213ac374af6d99e11d6c014",
    "download_url": "/api/device/employees/images/face-E001-v4"
  },
  "health_certificate": {
    "code": "HC2026001",
    "start_date": "2026-01-01",
    "end_date": "2027-01-01",
    "status": "VALID",
    "image": null
  },
  "version": 4,
  "updated_at": 1787788800000
}
```

字段	类型	必填	说明
<code>employee_id</code>	string	是	同一食堂内稳定唯一
<code>name</code>	string	是	姓名
<code>id_card_number</code>	string/null	否	身份证号
<code>phone</code>	string/null	否	电话
<code>position</code>	string/null	否	职位
<code>department</code>	string/null	否	部门
<code>status</code>	string	是	<code>ACTIVE</code> 或 <code>DISABLED</code>
<code>face_image</code>	object/null	否	人脸图片引用
<code>health_certificate</code>	object/null	否	健康证
<code>version</code>	long	是	平台维护的员工版本

字段	类型	必填	说明
updated_at	long	是	平台更新时间，毫秒

平台下发的健康证 status 建议接受并返回：

VALID、EXPIRING_SOON、EXPIRED、NOT_PROVIDED、REVOKED。

设备本地主要根据 end_date 重新计算有效状态。

6.2 图片引用

```
{
  "file_id": "face-E001-v4",
  "sha256":
  "6272c21f5b5b2c0f6c40c890f0a56eebf845f2482213ac374af6d99e11d6c014",
  "download_url": "/api/device/employees/images/face-E001-v4"
}
```

三个字段都必须返回。当前设备实际使用 file_id 拼接标准下载接口，并使用 sha256 校验；不会直接请求 download_url。

6.3 图片上传操作

```
{
  "action": "REPLACE",
  "mime_type": "image/jpeg",
  "sha256":
  "6272c21f5b5b2c0f6c40c890f0a56eebf845f2482213ac374af6d99e11d6c014",
  "base64": "/9j/4AAQSkZJRgABAQ..."
}
```

action	其他字段	平台行为
KEEP	其他字段为 null	保留当前图片
CLEAR	其他字段为 null	删除当前图片
REPLACE	mime_type、sha256、base64 必填	校验并替换图片

设备当前上传图片的 mime_type 为 image/jpeg。

7. 上传员工变更

7.1 请求

```
POST /api/device/employees/changes
Content-Type: application/json
```

```
api-key: {API Key}
```

设备当前每批最多上传 20 条操作。

```
{
  "device_id": "DEVICE001",
  "batch_id": "6b152909-7bb8-4d9f-8e40-624b66998b13",
  "timestamp": 1787788800000,
  "operations": [
    {
      "operation_id": "bd43ca64-ad6f-42c3-88cd-edf70985df89",
      "type": "UPSERT",
      "employee_id": "E001",
      "expected_version": 3,
      "employee": {
        "name": "张三",
        "id_card_number": "110101199001011234",
        "phone": "13800138000",
        "position": "厨师",
        "department": "后厨",
        "status": "ACTIVE",
        "face_image": {
          "action": "KEEP",
          "mime_type": null,
          "sha256": null,
          "base64": null
        },
        "health_certificate": {
          "code": "HC2026001",
          "start_date": "2026-01-01",
          "end_date": "2027-01-01",
          "status": "VALID",
          "image": {
            "action": "KEEP",
            "mime_type": null,
            "sha256": null,
            "base64": null
          }
        }
      }
    },
    {
      "operation_id": "75ba6f64-06ce-42cc-b227-90b65ddd5683",
      "type": "DELETE",
      "employee_id": "E002",
      "expected_version": 5,
      "employee": null
    }
  ]
}
```

7.2 字段规则

字段	类型	必填	说明
device_id	string	是	设置中配置的设备 ID；未配置时设备拒绝上传员工变更
batch_id	UUID string	是	单次 HTTP 批次追踪 ID
timestamp	long	是	本次 HTTP 请求生成时间
operations	array	是	当前设备每批 1 至 20 条
operation_id	UUID string	是	单条业务操作幂等键
type	string	是	UPSERT 或 DELETE
employee_id	string	是	员工业务主键
expected_version	long/null	是	首次创建为 null，修改/删除为当前平台版本
employee	object/null	是	UPSERT 为完整员工状态，DELETE 为 null

operation_id 在重试时保持不变，是平台必须使用的幂等键。当前代码在每次重试时会重新生成 batch_id 和 timestamp，平台不得把二者作为业务幂等键。

员工在平台已软删除后，设备重新添加相同 employee_id 时，会使用最后一次删除确认返回的 employee_version 作为 expected_version，平台应将该操作解释为恢复员工，而不是首次创建。

employee.health_certificate.status 由当前设备健康证计算结果生成，实际可能为：
VALID、EXPIRING_SOON、EXPIRED、NOT_PROVIDED。

7.3 成功响应

```
{
  "code": 200,
  "message": "success",
  "data": {
    "batch_id": "6b152909-7bb8-4d9f-8e40-624b66998b13",
    "accepted": 1,
    "duplicates": 0,
    "conflicts": 1,
    "rejected": 0,
    "server_cursor": 105,
    "results": [
      {
        "operation_id": "bd43ca64-ad6f-42c3-88cd-edf70985df89",
        "employee_id": "E001",
        "status": "APPLIED",
        "employee_version": 4,
        "cursor": 104,
        "error_code": null,
        "message": "success"
      }
    ]
  }
},
```

```
{
  {
    "operation_id": "75ba6f64-06ce-42cc-b227-90b65ddd5683",
    "employee_id": "E002",
    "status": "CONFLICT",
    "employee_version": 7,
    "cursor": null,
    "error_code": 40910,
    "message": "version conflict"
  }
}
```

data 必须包含：

accepted、**duplicates**、**conflicts**、**server_cursor**、**results**。

batch_id 和 **rejected** 当前客户端可缺省。平台必须为请求中的每条操作返回一个 **results** 元素。

results[].status	设备行为
APPLIED	删除本地 outbox，并保存 employee_version
DUPLICATE	视为成功，保存 employee_version 并删除本地 outbox
CONFLICT	标记员工冲突，停止自动上传该操作
REJECTED	标记操作失败，停止自动上传该操作

APPLIED 和 **DUPLICATE** 都必须返回当前 **employee_version**。实际发生数据变化时，**APPLIED** 还应返回该变化的 **cursor**。

平台必须对 **operation_id** 做持久化幂等。重复操作应返回 **DUPLICATE**，不得再次增加员工版本或生成新游标。

8. 拉取员工增量

8.1 请求

```
GET /api/device/employees/changes?after_cursor=100&limit=100
api-key: {API Key}
```

参数	必填	说明
after_cursor	是	设备已完整应用的最后游标；初始值可为 0
limit	是	当前设备默认发送 100

平台必须按 **cursor** 严格升序返回。

8.2 响应

```
{
  "code": 200,
  "message": "success",
  "data": {
    "changes": [
      {
        "cursor": 101,
        "type": "UPSERT",
        "employee_id": "E001",
        "employee_version": 4,
        "origin_device_id": "DEVICE002",
        "employee": {
          "employee_id": "E001",
          "name": "张三",
          "id_card_number": null,
          "phone": "13800138000",
          "position": "厨师",
          "department": "后厨",
          "status": "ACTIVE",
          "face_image": null,
          "health_certificate": null,
          "version": 4,
          "updated_at": 1787788800000
        }
      },
      {
        "cursor": 102,
        "type": "DELETE",
        "employee_id": "E002",
        "employee_version": 8,
        "origin_device_id": "DEVICE002",
        "employee": null
      }
    ],
    "next_cursor": 102,
    "has_more": false,
    "server_time": 1787788800000
  }
}
```

`data.changes`、`next_cursor`、`has_more`、`server_time` 都必须存在。

规则：

1. UPSERT 的 `employee` 必须非空。
2. DELETE 的 `employee` 必须为 `null`。
3. `employee_version` 与员工对象中的 `version` 必须一致。
4. `has_more=true` 时，设备会立即使用新的本地游标继续拉取。
5. 空结果也必须返回正确的 `next_cursor`。
6. 平台返回业务码 41010 时，设备判定游标过期并切换到完整快照。
7. `server_cursor` 不能代替增量接口的 `next_cursor`。

9. 查询单个员工

9.1 请求

```
GET /api/device/employees/E001
api-key: {API Key}
```

该接口用于版本冲突处理和定向修复。

9.2 有效员工响应

```
{
  "code": 200,
  "message": "success",
  "data": {
    "employee_id": "E001",
    "deleted": false,
    "version": 4,
    "employee": {
      "employee_id": "E001",
      "name": "张三",
      "status": "ACTIVE",
      "face_image": null,
      "health_certificate": null,
      "version": 4,
      "updated_at": 1787788800000
    }
  }
}
```

9.3 已删除员工响应

```
{
  "code": 200,
  "message": "success",
  "data": {
    "employee_id": "E001",
    "deleted": true,
    "version": 5,
    "employee": null
  }
}
```

员工删除后平台仍需保留并返回最后版本号。

10. 拉取完整员工快照

10.1 请求

```
GET /api/device/employees/snapshot
api-key: {API Key}
```

设备在游标过期、首次恢复或人工触发全量同步时调用。

10.2 响应

```
{
  "code": 200,
  "message": "success",
  "data": {
    "employees": [],
    "total": 0,
    "cursor": 105,
    "server_time": 1787788800000
  }
}
```

`employees`、`total`、`cursor`、`server_time` 必须存在。`total` 必须等于 `employees` 数量。

当前接口没有分页参数，平台必须在 60 秒内返回完整快照。数据量较大时，应通过合理压缩响应、数据库索引和图片引用分离保证性能；快照中不得内嵌图片 Base64。

设备应用快照后，会删除本地存在但快照中不存在且已经同步完成的员工，并把本地游标更新为 `cursor`。

11. 下载员工图片

11.1 请求

```
GET /api/device/employees/images/face-E001-v4
api-key: {API Key}
```

11.2 成功响应

- HTTP 状态为 `2xx`
- Body 为图片原始二进制
- `Content-Type` 为 `image/jpeg` 或 `image/png`
- 图片二进制 SHA-256 必须与员工对象中的 `sha256` 一致

平台不得在 HTTP `2xx` 中返回 JSON 错误。设备发现响应 `Content-Type` 包含 `json` 时会直接判定下载失败。

设备下载后还会解码图片；无法解码或 SHA-256 不一致时不会更新本地人脸图片。

12. 平台必须实现的可靠性规则

- 1. API Key 必须绑定租户、食堂和设备，所有查询必须隔离数据。
- 2. 晨检记录按 `device_id + record_uuid` 幂等。
- 3. 员工操作按 `operation_id` 幂等。
- 4. 员工每次实际变化生成单员工递增 `version`。
- 5. 每次实际员工变化生成食堂范围单调递增 `cursor`。
- 6. 员工数据、图片元数据、版本和变化日志必须在同一数据库事务内提交。
- 7. `expected_version` 不一致时返回 `CONFLICT`，不能覆盖最新数据。
- 8. 删除员工必须保留删除版本和 `DELETE` 变化日志。
- 9. 图片必须先校验 Base64、类型、大小和 SHA-256，再提交员工事务。
- 10. 所有失败响应必须使用正确 HTTP 状态，不得始终返回 HTTP `200`。

13. 建议 HTTP 状态码

HTTP 状态	场景
200	成功或幂等成功
400	JSON 或参数格式错误
401	API Key 缺失或无效
403	API Key 无权访问该设备或食堂
404	员工或图片不存在
409	晨检幂等键内容冲突
410	员工增量游标已过期，业务码使用 41010
413	请求体超过平台限制
422	字段组合、枚举、图片或 SHA-256 校验失败
429	限流
500、502、503、504	平台临时故障

14. 联调验收

14.1 自动化契约测试

在项目根目录执行：

```
./gradlew :app:testDebugUnitTest \
--tests "com.smartcheck.app.api.model.MorningCheckUploadRequestTest" \
--tests "com.smartcheck.app.data.sync.EmployeeSyncApiContractTest" \
--tests "com.smartcheck.app.data.sync.EmployeeSyncEngineTest" \
--tests "com.smartcheck.app.api.DeviceApiContractTest"
```

测试会验证：

- 晨检 JSON 字段名及空图片 `null` 行为
- 员工上传方法、路径、`api-key` 和 `Content-Type`
- 增量拉取的 `after_cursor` 和 `limit`
- 单员工和快照接口实际路径
- 平台响应模型可被当前 App 反序列化
- 设备侧 18 个路由、JWT 保护和静态路由匹配
- 设备侧分页参数校验

14.2 真实平台冒烟测试

仓库提供：

```
python3 tools/platform_api_smoke_test.py \
  --base-url "https://platform.example.com" \
  --api-key "YOUR_API_KEY"
```

默认验证心跳、员工增量和员工快照，不写入员工或晨检业务数据。

可按需增加：

```
--employee-id E001
--file-id face-E001-v4
--morning-check-json /path/to/morning-check.json
--employee-changes-json /path/to/employee-changes.json
```

两个 JSON 参数会真实写入平台，只能使用专用测试租户和测试数据。

15. 代码对应关系

协议内容	代码文件
7 个平台路径	<code>api/PlatformApiContract.kt</code>
18 个设备路径	<code>api/DeviceApiContract.kt</code>
晨检请求/响应字段	<code>api/model/ApiModels.kt</code>
员工同步字段	<code>api/model/SyncModels.kt</code>
员工字段映射	<code>api/model/PlatformEmployeeMapper.kt</code>
员工批次、游标、冲突处理	<code>data/sync/EmployeeSyncEngine.kt</code>
晨检重试和幂等身份	<code>data/upload/PendingUploadManager.kt</code>

协议内容	代码文件
JSON 客户端配置	di/AppModule.kt
契约测试	MorningCheckUploadRequestTest.kt、EmployeeSyncApiContractTest.kt、EmployeeSyncEngineTest.kt、DeviceApiContractTest.kt

后续修改接口路径或模型字段时，必须同时修改本文档和对应契约测试。

16. 设备端 REST API 概述

晨检仪内嵌 Ktor HTTP 服务，监听固定端口：

```
http://{设备局域网IP}:8080
```

当前 App 本身未配置 TLS，设备端直接提供 HTTP。跨公网接入时必须通过 VPN、专线或可信反向代理提供 HTTPS，不应把设备的 8080 端口直接暴露到互联网。

设备端共开放 18 个接口：

序号	方法	路径	认证	用途
1	GET	/health	否	服务健康检查
2	POST	/api/auth/login	否	登录并获取 JWT
3	POST	/api/users/sync	是	同步设备登录账号
4	GET	/api/records	是	分页查询晨检记录
5	GET	/api/records/sync	是	按本地记录 ID 增量拉取
6	GET	/api/records/statistics	是	查询晨检统计
7	GET	/api/records/{id}	是	查询单条晨检记录
8	POST	/api/records/export	是	导出 CSV
9	GET	/api/employees	是	分页查询员工
10	GET	/api/employees/sync	是	按本地员工 ID 增量拉取
11	POST	/api/employees/import	是	批量导入或覆盖员工
12	POST	/api/employees/upload-photo	是	上传员工人脸照片
13	POST	/api/employees/upload-cert-photo	是	上传健康证照片
14	DELETE	/api/employees/clear-all	是	清空员工
15	DELETE	/api/employees/{employeeId}	是	删除指定员工
16	GET	/api/images/{filename}	是	下载晨检图片

序号	方法	路径	认证	用途
17	GET	/api/employee-images/{filename}	是	下载员工图片
18	GET	/api/downloads/{filename}	是	下载导出文件

17. 设备端通用约定

17.1 JWT 认证

除 /health 和 /api/auth/login 外，请求必须携带：

```
Authorization: Bearer {token}
```

JWT 有效期为 24 小时，登录响应中的 expiresIn 单位为秒。

未携带或 Token 无效时返回 HTTP 401：

```
{
  "code": 1001,
  "message": "Token 无效或已过期"
}
```

鉴权错误当前使用简化错误对象，不包含 data。

17.2 设备端 JSON 包装

业务成功统一返回：

```
{
  "code": 0,
  "message": "success",
  "data": {}
}
```

业务失败通常返回：

```
{
  "code": 1004,
  "message": "参数错误"
}
```

设备端成功码是 0，与平台侧接口成功码 200 不同。客户端必须同时检查 HTTP 状态和 JSON code。

设备 JSON 配置为 explicitNulls=false。值为 null 的 data 或其他可选字段会直接省略。

17.3 设备端错误码

业务码	说明
0	成功
1001	未授权
1002	禁止访问
1003	资源不存在
1004	参数错误
1005	服务器内部错误
1006	Token 过期
2005	用户名已存在
2006	数据验证失败
2009	密码不能为空
2010	角色无效
2011	状态无效

18. 健康检查与登录

18.1 健康检查

GET /health

```
{
  "code": 0,
  "message": "success",
  "data": {
    "status": "ok",
    "timestamp": 1787788800000
  }
}
```

18.2 登录

POST /api/auth/login
Content-Type: application/json

```
{
  "username": "admin",
  "password": "设备管理员密码"
}
```

成功响应：

```
{
  "code": 0,
  "message": "success",
  "data": {
    "token": "eyJhbGciOiJIUzI1NiIs... ",
    "expiresIn": 86400,
    "tokenType": "Bearer",
    "user": {
      "id": 1,
      "username": "admin",
      "name": "管理员"
    }
  }
}
```

设备出厂默认管理员账号为 admin，默认密码为 123456。正式部署前必须修改默认密码，并限制 8080 端口只允许受信网络访问。

19. 设备员工接口

19.1 查询员工列表

```
GET /api/employees?page=1&pageSize=20&employeeId=E001&isActive=true
Authorization: Bearer {token}
```

参数	必填	约束
page	否	默认 1，必须大于等于 1
pageSize	否	默认 20，范围 1..100
employeeId	否	员工工号精确匹配，区分大小写
isActive	否	true 或 false

响应：

```
{
  "code": 0,
```

```
"message": "success",
"data": {
  "list": [
    {
      "id": 1,
      "name": "张三",
      "employeeId": "E001",
      "idCardNumber": "110101199001011234",
      "healthCertStatus": "VALID",
      "healthCertStartDate": 1767225600000,
      "healthCertEndDate": 1798761600000,
      "faceImage": "/api/employee-images/face_emp_1.jpg",
      "healthCertImage": "/api/employee-images/cert_emp_1.jpg",
      "isActive": true,
      "createdAt": 1787788800000
    }
  ],
  "pagination": {
    "page": 1,
    "pageSize": 20,
    "total": 1,
    "totalPages": 1
  }
}
```

healthCertStatus 可能为 VALID、EXPIRING_SOON、EXPIRED、NOT_PROVIDED。

19.2 员工增量拉取

```
GET /api/employees/sync?lastEmployeeId=0&limit=100
Authorization: Bearer {token}
```

参数	必填	约束
lastEmployeeId	否	默认 0，必须大于等于 0
limit	否	默认 100，设备自动限制到 1..500

```
{
  "code": 0,
  "message": "success",
  "data": {
    "list": [],
    "hasMore": false,
    "lastRecordId": 0,
    "syncTime": 1787788800000
  }
}
```

```
}  
}
```

响应字段 `lastRecordId` 实际表示最后一个员工的设备本地数字 ID。下次请求将它作为 `lastEmployeeId`。

该接口只按本地自增 ID 获取新增行，不提供修改或删除事件。需要可靠双向员工同步时，应使用本文第 6 至 11 节的平台员工同步协议。

19.3 批量导入员工

```
POST /api/employees/import  
Authorization: Bearer {token}  
Content-Type: application/json
```

```
{  
  "employees": [  
    {  
      "name": "张三",  
      "employeeId": "E001",  
      "idCardNumber": "110101199001011234",  
      "phone": "13800138000",  
      "position": "厨师",  
      "department": "后厨",  
      "healthCertCode": "HC2026001",  
      "faceImageBase64": null,  
      "healthCertImageBase64": null,  
      "healthCertStartDate": 1767225600000,  
      "healthCertEndDate": 1798761600000,  
      "isActive": true  
    }  
  ],  
  "incremental": true  
}
```

- `employees` 长度为 1 至 100。
- 同一请求中不能有重复 `employeeId`。
- `incremental=true` 时跳过设备中已存在的工号。
- `incremental=false` 时覆盖已有员工的普通字段；未传图片时保留已有图片。
- 人脸图片存在时，设备尝试检测人脸并提取本地特征。
- 单个员工失败不会回滚同批其他已成功员工。

响应详情状态为 `success`、`skipped`、`updated` 或 `failed`。

19.4 上传员工人脸照片

```
POST /api/employees/upload-photo
Authorization: Bearer {token}
Content-Type: application/json
```

```
{
  "fileName": "face_E001.jpg",
  "imageBase64": "/9j/4AAQSkZJRgABAQ..."
}
```

- 文件名必须匹配 `face_{employeeId}.jpg`。
- `employeeId` 只允许字母、数字和下划线，匹配时保留原大小写。
- 员工必须已存在。
- 图片必须可解码且至少检测到一张人脸。
- 设备成功提取人脸特征并保存员工后才返回成功。

19.5 上传健康证照片

```
POST /api/employees/upload-cert-photo
Authorization: Bearer {token}
Content-Type: application/json
```

```
{
  "fileName": "cert_E001.png",
  "imageBase64": "iVBORw0KGgoAAA..."
}
```

文件名必须匹配 `cert_{employeeId}.jpg`、`.jpeg` 或 `.png`。设备最终会重新编码并以 JPEG 文件保存。

19.6 删除员工

```
DELETE /api/employees/E001
Authorization: Bearer {token}
```

```
{
  "code": 0,
  "message": "success",
  "data": {
    "employeeId": "E001",
    "deleted": true
  }
}
```



```
}  
}
```

员工不存在时返回 HTTP 404 和业务码 1003。

19.7 清空员工

```
DELETE /api/employees/clear-all  
Authorization: Bearer {token}
```

该操作直接删除设备本地全部员工且不可恢复。

19.8 与平台员工同步的关系

设备 REST 员工导入、照片上传、删除和清空接口是直接管理单台设备本地数据库的兼容接口，不会生成平台员工同步 outbox。

在多设备共享员工库场景中：

- 1. 平台主数据应通过第 6 至 11 节的员工同步协议下发。
- 2. 不应使用 /api/employees/import 分别覆盖多台设备。
- 3. 不应在平台同步运行期间调用 /api/employees/clear-all。
- 4. 平台调用单台设备 REST 员工接口产生的变化不会自动传播到其他设备。

20. 设备晨检记录接口

20.1 分页查询记录

```
GET /api/records?startDate=2026-08-01&endDate=2026-08-27&page=1&pageSize=20  
Authorization: Bearer {token}
```

参数	必填	约束
startDate	是	yyyy-MM-dd
endDate	是	yyyy-MM-dd，不能早于开始日期
employeeId	否	员工工号精确匹配
isPassed	否	true 或 false
isTempNormal	否	true 或 false
isHandNormal	否	true 或 false
includeImages	否	默认 false
page	否	默认 1，必须大于等于 1

参数	必填	约束
pageSize	否	默认 20，范围 1..100

记录对象：

```
{
  "id": 1001,
  "userId": 1,
  "userName": "张三",
  "employeeId": "E001",
  "checkTime": 1787788800000,
  "temperature": 36.5,
  "isTempNormal": true,
  "isHandNormal": true,
  "isPassed": true,
  "handStatus": "NORMAL",
  "healthCertStatus": "VALID",
  "symptomFlags": "",
  "remark": "",
  "images": {
    "face": "/api/images/face_1001.jpg",
    "palm": "/api/images/palm_1001.jpg",
    "back": "/api/images/back_1001.jpg"
  }
}
```

includeImages=false 时 images 字段会被省略。

20.2 查询单条记录

```
GET /api/records/1001?includeImages=true
Authorization: Bearer {token}
```

includeImages 默认值为 true。记录不存在时返回 HTTP 404。

20.3 增量拉取记录

```
GET /api/records/sync?lastRecordId=0&limit=100
Authorization: Bearer {token}
```

- lastRecordId 必填且必须大于等于 0。
- limit 默认 100，设备自动限制到 1..500。
- 响应 list 不包含图片 URL。
- hasMore=true 时继续使用返回的 lastRecordId 拉取。

该接口只按设备本地自增 ID 拉取新增记录。记录一旦开始上传后不能修改，因此该增量模型适用于当前业务。

20.4 晨检统计

```
GET /api/records/statistics?startDate=2026-08-01&endDate=2026-08-27
Authorization: Bearer {token}
```

响应字段：

`totalCheck`、`passed`、`failed`、`tempAbnormal`、`handAbnormal`、`dailyStats`。

20.5 导出 CSV

```
POST /api/records/export
Authorization: Bearer {token}
Content-Type: application/json
```

```
{
  "startDate": "2026-08-01",
  "endDate": "2026-08-27",
  "format": "csv",
  "employeeId": "E001"
}
```

- 当前仅支持 `csv`。
- `employeeId` 不为空时会按员工工号过滤。
- 返回的下载文件有效期为 1 小时。

```
{
  "code": 0,
  "message": "success",
  "data": {
    "downloadUrl": "/api/downloads/records_2026-08-01_2026-08-27.csv",
    "expiresAt": 1787792400000
  }
}
```

21. 设备文件下载

所有文件下载接口都需要 JWT：

接口	数据来源
GET /api/images/{filename}	晨检人脸、手心、手背图片
GET /api/employee-images/{filename}	员工人脸和健康证图片
GET /api/downloads/{filename}	临时 CSV 文件

成功响应是文件二进制。失败响应是 JSON 错误。

安全规则：

- filename 不能为空。
- 文件名不能包含 ..、/ 或 \。
- CSV 文件超过 1 小时后，首次下载请求会删除过期文件并返回 HTTP 404。
- 响应中的图片 URL 是相对路径，下载时仍需携带 JWT。

22. 设备登录账号同步

该接口同步的是可以登录设备的系统账号，不是员工档案。

```
POST /api/users/sync
Authorization: Bearer {token}
Content-Type: application/json
```

```
{
  "action": "create",
  "syncTime": 1787788800000,
  "users": [
    {
      "username": "operator01",
      "password": "123456",
      "passwordType": "plain",
      "employeeId": "E001",
      "role": "employee",
      "status": "active"
    }
  ]
}
```

字段	必填	说明
action	是	create、update、delete、sync
syncTime	否	当前设备接收但不参与处理
users	是	1 至 100 条
username	是	登录用户名

字段	必填	说明
password	条件	create、sync 应提供；update 不传则保留
passwordType	否	默认 plain
employeeId	否	关联员工工号
role	否	默认 employee
status	否	默认 active

操作行为：

action	行为
create	新增账号，已存在则该条失败
update	更新账号，不存在则该条失败
delete	删除账号，不存在则该条失败
sync	先清空设备全部系统账号，再逐条新增

当前版本对 role、status 和 passwordType 的取值没有完整服务端校验，接入方应严格使用本文示例值。密码类型建议只使用 plain；设备尚未集成真正的 BCrypt 校验。

23. 设备端使用限制

- 1. 设备端 REST 服务适合受信局域网内的管理、查询和兼容对接。
- 2. 不应把 8080 端口直接发布到公网。
- 3. 出厂默认管理员密码必须在部署时修改。
- 4. 所有文件 URL 都是相对路径，且下载接口需要 JWT。
- 5. 设备端成功业务码为 0，平台侧成功业务码为 200。
- 6. 设备员工 REST 接口与平台双向员工同步是两套不同的数据写入路径，不应混用。
- 7. 账号 action=sync 会先清空所有设备登录账号，调用失败可能造成部分同步状态。
- 8. 批量员工导入和账号同步均是逐条处理，不提供整批事务回滚。

24. 设备端验收请求

基础连通性：

```
curl "http://DEVICE_IP:8080/health"
```

登录：

```
curl -X POST "http://DEVICE_IP:8080/api/auth/login" \
-H "Content-Type: application/json" \
-d '{"username":"admin","password":"DEVICE_PASSWORD"}'
```

记录统计:

```
curl "http://DEVICE_IP:8080/api/records/statistics?startDate=2026-08-01&endDate=2026-08-27" \  
-H "Authorization: Bearer TOKEN"
```

员工查询:

```
curl "http://DEVICE_IP:8080/api/employees?page=1&pageSize=20" \  
-H "Authorization: Bearer TOKEN"
```